

Admin CRM Audit Report

Date: 2026-07-29

Scope: Admin access only

Modules audited: Dashboard, Notifications, Users, Items, Leads, Prospects, Quotations, Customers, Reports, Profile, Settings, Help

Audit method: Static code and architecture review of frontend, backend, route guards, Prisma models, validation schemas, service logic, subscription gates, and UI flows.

Note: No application code or functionality was modified for this audit. This report and its PDF export are the only artifacts created.

Executive Summary

Admin access has a strong base: non-super-admin users are pinned to their own organization by backend middleware, suspended organizations are blocked at authentication time, most tenant write routes are subscription-gated, and Admin role permissions are generally narrower than Super Admin permissions.

The highest risk is not broad Admin access across organizations. The highest risk is data integrity inside the Admin organization. Admins can currently delete converted leads, and prospects are hard-deleted even when they are terminal WON or LOST. Because customers are derived from Prospect.stage === WON, these delete paths can damage customer lineage, reports, and historical CRM data.

The second major risk is API-side validation and authorization drift. The Leads API accepts a raw productInterested item id without confirming that the item belongs to the same organization. The Profile API accepts organization PDF asset uploads from any authenticated organization user if they craft the request, even though the UI only exposes this to Admin and Manager.

Top priorities:

Priority	Severity	Issue	Main affected area
P0	Critical	Admin can delete converted leads and hard-delete terminal/customer prospects	Leads, Prospects, Customers, Reports
P0	High	Lead productInterested can connect to an item from another organization by crafted API request	Leads, Items, tenant isolation
P0	High	Organization PDF assets are guarded by UI only, not backend role permission	Profile, quotation PDF assets
P0	High	/quotations/stats is shadowed by /:id, causing quotation stat cards to fail or show zero	Quotations
P1	High	Approved quotations do not automatically create customers or mark prospects as WON	Quotations, Customers
P1	Medium	Admin audit trail is incomplete for important workflow actions	Leads, Items, Prospects, Profile, Reports
P1	Medium	Several UI stats count current page or capped data instead of true organization totals	Users, Items, Prospects
P1	Medium	Reports endpoint computes all report tabs for each tab request and uses in-memory aggregation	Reports
P2	Low	Help content is outdated and contains Admin guidance for actions Admin cannot perform	Help

Cross-Cutting Admin Architecture Findings

Role and Permission Control

Observed:

- Admin has backend permissions for users, items, leads, prospects, quotations, reports, audit read, announcements, billing read, dashboard read, and organization read/update.
- Admin cannot create Admin users through the backend permission utility; Admin can create Manager and Executive users.
- Super Admin-only password reset is enforced in `userService.resetUserPassword`, even though the route uses a broader `USER_UPDATE` permission.
- Admin dashboard route additionally enforces exact role match.

Issues:

- Some sensitive capabilities rely on frontend hiding rather than backend authorization. The clearest example is Profile organization asset upload.
- Admin-visible Help still says Admin can reset user passwords, but backend restricts this to Super Admin.

Best-practice solution:

- Treat frontend role checks as UX only.
- Add backend permission checks for every role-sensitive file field and workflow action.
- Maintain a role capability matrix and test it at API level for Admin, Manager, Executive, and Super Admin.

Organization Data Isolation

Observed:

- `requireOrganization` pins every non-super-admin request to `req.user.organizationId`.
- Core tenant modules query by `organizationId`.
- Suspended organizations are blocked in `requireAuth`.

Issues:

- Lead `productInterested` is connected by item id without validating the item belongs to the same organization.
- Prospect and quotation flows validate many related records correctly, but Lead item relation is a gap.

Best-practice solution:

- Validate every foreign key relation with `{ id, organizationId, deletedAt: null }` before connecting it.
- Prefer composite constraints or service-level guards for cross-organization-sensitive relations.

Subscription and Plan Restrictions

Observed:

- Writes in Users, Items, Leads, Prospects, and Quotations are blocked when a subscription is read-only.
- Dashboard, Reports, Billing, Audit, notification feed, and announcement feed stay readable for lapsed tenants.
- Feature toggles gate announcement authoring and audit-log access.

Issues:

- Subscription checks fail open when an organization has no subscription. This is documented as a migration/backfill safety path, but it means a stranded Admin can continue writing.
- Quotation PDF is client-rendered, so the `QUOTATION_PDF` feature is effectively a UI gate.

Best-practice solution:

- Monitor and alert on `SUBSCRIPTION_MISSING`.
- Add a startup/backfill invariant that every active organization has a subscription.
- For premium client-rendered features, ensure no server-side asset/export endpoint can bypass the plan.

Audit Completeness

Observed:

- User create/update/delete/disable/enable, item create/update/delete, lead create/update/status/delete/import/convert, quotation create/update/status/delete, and auth profile/password events are audited.

Issues:

- Missing or weak audit coverage for Admin-relevant actions:
 - Lead assignment.
 - Item status toggle.
 - Prospect stage change.
 - Prospect follow-up update.
 - Prospect manual activity creation.
 - Prospect delete.
 - Profile image and organization PDF asset uploads.
 - Report CSV export.

Best-practice solution:

- Define an Admin audit event matrix.
- Record audit rows after successful business operations.
- Capture before/after snapshots for state changes, but never log secrets or full personal/file data.

Module-Wise Admin Audit Report

1. Dashboard

Severity: Medium

Affected functionality:

- Admin KPI cards.
- Lead source/status charts.
- Lead and sales trends.
- Manager and executive performance tables.
- Dark mode chart readability.

Bugs/issues found:

- Lost Leads counts only leads with status UNQUALIFIED. Lost prospects (Prospect.stage === LOST) are not included, so the KPI can understate lost pipeline.
- Conversion Rate % is calculated as prospects divided by total leads. This is a lead-to-prospect conversion rate, not customer conversion or sales conversion.
- Follow-up due and overdue calculations compare a Date column and a string followUpTime using the server timezone, which can misclassify today/overdue around timezone boundaries.
- Team performance includes only active managers/executives. Historical work from inactive users disappears from current dashboard performance.
- Lead and quotation trend data is fetched into memory and bucketed in JavaScript.
- Chart axes use hard-coded black tick colors in Admin dashboard charts, which can be hard to read in dark mode.

Possible root cause:

- KPI names do not fully encode business definitions.
- Trend and performance logic was optimized for fast delivery, not large datasets.
- Frontend chart styling bypasses theme tokens.

Best-practice solution:

- Rename KPIs or update calculations:

- Lost Leads should either stay direct lost leads or become Lost Pipeline and include lost prospects.
- Conversion Rate should be named Lead to Prospect Rate.
- Move trend aggregation into database queries or materialized summary tables.
- Store follow-up date/time as a single timezone-aware timestamp or normalize by organization timezone.
- Use theme-aware chart tokens for axis labels and grid colors.

Performance improvement suggestions:

- Use database groupBy or raw SQL date bucketing for trends.
- Cache dashboard stats for a short period per organization.
- Keep inactive users in historical performance with an Inactive badge.

Edge cases to test:

- Organization with no leads, no prospects, and no quotations.
- Leads converted to prospects, then prospect marked LOST.
- Admin timezone different from server timezone.
- Follow-up today with null time, past time, and future time.
- Inactive executive with historical won customers and approved quotations.

Testing checklist:

- Verify all KPI numbers against direct database counts.
- Verify lost pipeline definition with both UNQUALIFIED leads and LOST prospects.
- Verify conversion rate label and formula.
- Verify follow-up due/overdue around midnight.
- Verify dashboard in dark and light mode.
- Verify dashboard with large lead/quotation volumes.

2. Notifications

Severity: Low to Medium

Affected functionality:

- Notification page.
- Notification bell/unread count.
- Announcement visibility in Admin feed.
- Mark all read behavior.

Bugs/issues found:

- Per-user notifications are correctly scoped by userId.
- Announcement feed visibility is handled separately and supports role/org targeting.
- Notification mark all read updates only one bounded batch of 200. Announcement mark all read loops until cleared, but notification mark all read can leave unread items when a user has more than 200.
- Notifications page passes loading={announcementsLoading && notificationsLoading}. If only one source is loading, the UI may show partial or stale content instead of a loading state.
- The full notifications page loads a bounded notification feed, not true paginated history.

Possible root cause:

- Notification feed was designed as a lightweight bell feed and reused on the full page.
- Announcement and notification read models evolved differently.

Best-practice solution:

- Make notification mark all read loop like announcements or rename the action to Mark latest read.
- Use announcementsLoading || notificationsLoading where full-feed loading matters.
- Add pagination or infinite scroll for notification history.

Performance improvement suggestions:

- Index notification queries by (userId, readAt, createdAt).
- Keep unread counts cheap with count queries or cached counters if volume grows.

Edge cases to test:

- Admin with 201 unread notifications.
- Announcement unread count plus notification unread count.
- Dismissible vs non-dismissible announcements.
- Lapsed subscription Admin still reading notification/billing warnings.
- Announcement targeted to Admin role only.

Testing checklist:

- Verify Admin sees only own notifications.
- Verify Admin sees platform announcements targeted to their organization or role.
- Verify Admin sees organization announcements from their own org only.
- Verify mark all read clears all unread rows.
- Verify loading, empty, unread-only, and delete states.
- Verify mobile notification cards.

3. Users

Severity: Medium

Affected functionality:

- Manager and Executive creation.
- User list stats.
- Role assignment.
- Seat limits.
- Disable, enable, delete.

Bugs/issues found:

- Admin can create only Manager and Executive users, which is correct.
- Seat checks run on create and enable, which is correct.
- UsersStats calls useUsers() without pagination params and counts only the returned page. With more than 10 users, Admin stat cards are wrong.
- Frontend requires mobile and joiningDate, but backend makes them optional. This creates inconsistent policy between UI and API.
- Soft-deleted user email cannot be reused because User.email is globally unique. The service pre-check only checks active users, then the database unique constraint throws later.
- User filter limit has no maximum.
- Help content says Admin can reset passwords, but backend restricts reset-password to Super Admin.

Possible root cause:

- Stats are derived from list response instead of aggregate endpoints.
- Form schema diverged from shared backend schema.
- Soft delete and global unique email policy were not made explicit in UX.

Best-practice solution:

- Add a /users/stats endpoint or use filtered count calls by role/status.
- Align frontend and backend validation for mobile/joining date.
- Show a clear message when an email belongs to a deleted user and cannot be reused.
- Add limit.max(100) to user filters.

Performance improvement suggestions:

- Use database counts for user stats.
- Avoid loading full/capped user lists for aggregate cards.
- Add indexes for common org/role/status search if not already present.

Edge cases to test:

- Admin creates Manager.
- Admin creates Executive with and without manager.
- Admin attempts to create Admin.
- Admin disables an Executive with active sessions.
- Admin enables user when plan seat limit is reached.
- Admin tries duplicate email from active and soft-deleted user.

Testing checklist:

- Verify Admin cannot create Admin or Super Admin.
- Verify Manager can only create Executive.
- Verify self-disable/self-delete blocked.
- Verify seat limit on create and enable.
- Verify pagination/search/filter with more than one page.
- Verify mobile form validation matches API validation.
- Verify audit rows for create/update/disable/enable/delete.

4. Items

Severity: Medium

Affected functionality:

- Item catalogue.
- Quotation line items.
- Lead product interest.
- Item stats.
- Item status toggle.

Bugs/issues found:

- Item create/update/delete are audited, but item status toggle is not audited.
- Item filter limit has no maximum.
- ItemsStats loads limit: 1000 and counts client-side. This is heavy and becomes inaccurate above 1000 items.
- Item price and GST rate are stored as Float; quotation totals use Decimal later, but catalogue pricing can still carry floating precision risk.
- The service relies on database uniqueness for item code conflicts. The schema comment suggests an active-only uniqueness intent; verify the migration actually enforces active item code uniqueness per organization.

Possible root cause:

- Toggle was added as a convenience path but not included in audit matrix.
- Stats were built from list data instead of aggregate queries.

Best-practice solution:

- Add an audit row for ITEM_STATUS_CHANGED.
- Add true item aggregate stats endpoint.
- Add limit.max(100) or limit.max(500) to item filters.
- Store money-like fields as Decimal where possible.
- Confirm partial unique index for active item codes.

Performance improvement suggestions:

- Use DB counts by status/type.
- Keep quotation item lookup limited to active items with compact select fields.
- Add indexes for item search fields if catalogue grows.

Edge cases to test:

- Duplicate item code in same organization.

- Duplicate item code across organizations.
- Soft-deleted item code reuse.
- Inactive item used in existing quotation.
- Active item toggled inactive and then used in a new quotation.
- Large item catalogue.

Testing checklist:

- Verify item CRUD is org-scoped.
- Verify inactive/deleted items cannot be used in new quotations.
- Verify item status toggle creates audit log after fix.
- Verify item stats above 1000 records.
- Verify dark/light mode table and mobile cards.

5. Leads

Severity: Critical

Affected functionality:

- Lead creation.
- Lead assignment.
- Lead status flow.
- Qualified lead to prospect conversion.
- Lead deletion.
- Organization data isolation.

Bugs/issues found:

- productInterested / productInterestId is connected directly to Item by id. The backend does not verify that the item belongs to the Admin's organization. A crafted request can link a lead to another organization's item.
- Admin can delete converted leads. The update path prevents editing a converted lead at repository level, but the delete path only soft-deletes the lead and does not block converted lineage.
- Lead assignment is not audited.
- The quick status flow changes status to QUALIFIED and then separately calls conversion. If conversion fails because of plan limit or validation, the lead remains qualified but not converted.
- Lead profile image upload runs before validation. Invalid form data with a valid file can leave orphan upload files.
- Lead filter limit has no maximum.
- Individual lead create does not appear to enforce duplicate email/mobile policy, while import does. This creates inconsistent duplicate behavior.
- findLeadById used by business guards does not include prospect, so converted-lead checks depend on later repository behavior and miss delete.

Possible root cause:

- Relationship validation was handled for assignees but not item relation.
- Converted lead immutability was implemented in update but not delete.
- UI workflow split qualification and conversion into two calls.

Best-practice solution:

- Validate productInterested with item.findFirst({ id, organizationId, deletedAt: null, status: ACTIVE }) before connect.
- Block delete for any lead with a prospect, or convert lead delete into an archive policy that preserves prospect/customer lineage.
- Add LEAD_ASSIGNED audit event with before/after assignee.
- Provide a single backend action for "qualify and convert" or make UI show a recoverable intermediate state.
- Clean up uploaded files on validation/service failure.

- Add `limit.max(100)`.
- Decide and document duplicate email/mobile policy.

Performance improvement suggestions:

- Add DB indexes for lead search fields if volume grows.
- Use aggregate endpoints for lead stats.
- Avoid unbounded list requests for exports/import validation.

Edge cases to test:

- Admin creates lead with item id from another organization.
- Admin deletes a converted lead that has a prospect/customer.
- Admin changes status to QUALIFIED when prospect limit is reached.
- Admin imports duplicate emails and then manually creates same duplicate.
- Lead image upload with invalid body.
- Assignment to inactive user or user from another organization.

Testing checklist:

- Verify lead CRUD is organization-scoped.
- Verify product interest cannot cross organization.
- Verify converted lead cannot be deleted.
- Verify assignment creates audit log after fix.
- Verify qualify-to-prospect flow is atomic or recoverable.
- Verify import respects plan limits and duplicates.
- Verify pagination, filters, empty states, and mobile view.

6. Prospects

Severity: Critical

Affected functionality:

- Prospect pipeline.
- Follow-ups.
- Stage changes.
- Customer derivation.
- Prospect activity history.

Bugs/issues found:

- `deleteProspect` hard-deletes the prospect and does not call `assertEditableProspect`. Admin can delete WON or LOST prospects, including customer records.
- Prospect activities have `onDelete: Cascade`, so hard-deleting a prospect also deletes activity history.
- Prospect stage change, follow-up update, activity creation, and delete are not audited.
- Follow-up overdue logic mixes date fields, string time, UTC date construction, and server local hours. This can misclassify overdue status.
- `ProspectsStats` counts lost prospects from the current page only, while total prospects uses `meta.total`.
- Prospect filter limit has no maximum.
- `UpdateProspectSchema` requires name, email, mobile, and company name. Leads can have optional email/mobile/company; editing a prospect converted from incomplete lead data may force unrelated missing fields.
- Quotation party picker loads prospects by lead status QUALIFIED, not by active prospect stage. Terminal WON or LOST prospects can still appear if the lead remains qualified.

Possible root cause:

- Customer is modeled as a prospect stage, so delete rules need stronger terminal-state handling.
- Activity/audit trail responsibilities are split.
- Form validation does not support partial prospect updates.

Best-practice solution:

- Remove hard delete from Admin UI/API or convert to soft delete with terminal-state protection.
- Block delete for WON and LOST, or require an explicit archive workflow with audit.
- Add audit rows for stage, follow-up, activity, and delete.
- Make prospect updates partial where business rules allow.
- Normalize follow-up datetime handling.
- Add aggregate stats for lost prospects.

Performance improvement suggestions:

- Add indexes for organization/stage/assigned/follow-up queries.
- Avoid returning activity history in list endpoints.
- Use database counts for prospect stat cards.

Edge cases to test:

- Delete WON prospect/customer.
- Delete prospect with quotations and activities.
- Update stage to WON and verify customer list.
- Update stage to LOST and verify dashboard/reports.
- Follow-up due around timezone boundaries.
- Prospect converted from lead missing email/mobile/company.

Testing checklist:

- Verify Admin sees all organization prospects only.
- Verify terminal prospects are read-only or protected.
- Verify stage change requires comment and writes audit row after fix.
- Verify follow-up creation, completion, and overdue counts.
- Verify manual activity clears follow-up only when intended.
- Verify lost prospect stats across multiple pages.
- Verify mobile and dark mode behavior.

7. Quotations

Severity: High

Affected functionality:

- Quotation stats.
- Quotation status flow.
- PDF preview.
- Prospect/customer conversion.
- Quotation form selection.

Bugs/issues found:

- In quotation.route.ts, GET /:id is registered before GET /stats. Express matches /quotations/stats as id = "stats", so quotation stats are effectively unreachable. The frontend then falls back to zero stats.
- Quick status dialog sends only { status }. Backend requires statusReason when rejecting, so Admin cannot reject from the quick status dialog.
- Approving a quotation does not mark the linked prospect as WON. Since customers are derived from won prospects, approved quotations do not automatically create customers.
- Quotation form loads only first 100 items and first 100 qualifying prospects. Large organizations can have missing options.
- Quotation quick status changes omit expectedVersion, so concurrent status changes can overwrite each other.
- Default reference prefix/suffix appears hardcoded in the form (EBS/26 -, 2) and is not organization/year aware.
- Attachments are stored as base64 in quotation JSON. This is capped, but it increases DB size and response payloads.

- PDF preview is client-rendered and gated by QUOTATION_PDF in the UI. If PDF generation remains client-only, this is a UX gate rather than a strong server-side feature gate.

Possible root cause:

- Route ordering oversight.
- Backend status policy grew stricter than quick-action UI.
- Customer conversion rule is not encoded in quotation approval.
- Form options use fixed list limits.

Best-practice solution:

- Move /stats before /:id.
- Add rejection reason textarea when Admin selects REJECTED.
- Decide the business rule:
 - Approval automatically marks linked prospect WON, or
 - Admin must explicitly mark prospect won and UI should explain that approval alone does not create customer.
- Paginate/search party and item selectors.
- Include expectedVersion in quick actions.
- Store large attachments in object storage and snapshot metadata in DB.

Performance improvement suggestions:

- Keep quotation list excludes heavy details, which is good.
- Add server-side searchable item/prospect selector endpoints.
- Use object storage for attachments and PDF assets.

Edge cases to test:

- /quotations/stats returns real counts.
- Reject quotation without reason.
- Approve quotation linked to prospect and verify customer behavior.
- Edit approved quotation.
- Return approved quotation to pending.
- Delete approved quotation.
- Create quotation with inactive/cross-org item id.
- Create quotation with more than 100 available items/prospects.

Testing checklist:

- Verify route order for stats.
- Verify status transition matrix.
- Verify rejection reason is required and usable in UI.
- Verify status history and audit row.
- Verify PDF preview includes logo, QR code, and signature.
- Verify quotation totals are recalculated by backend.
- Verify mobile form usability.

8. Customers

Severity: High

Affected functionality:

- Customer list.
- Customer stats.
- Customer conversion from prospect/quotation.
- Customer lifecycle.

Bugs/issues found:

- Customers are not a separate model. Customer list is prospects filtered to stage: WON.
- Approved quotation does not automatically create or update a customer.
- Deleting a converted lead can make a won prospect/customer count as inactive or disappear from

active customer metrics.

- Hard-deleting a won prospect removes the customer record and activity history.
- There is no explicit customer status/lifecycle outside prospect stage and linked lead deletion status.

Possible root cause:

- The customer domain is currently represented as a terminal pipeline stage.
- Delete/archive rules were not strengthened after customer derivation was added.

Best-practice solution:

- Decide whether Customer should remain a derived view or become its own entity.
- If derived, block destructive operations on won prospects and converted leads.
- If separate, create customer records through a transaction when prospect becomes WON.
- Add customer lifecycle audit events.

Performance improvement suggestions:

- Keep customer stats as aggregate endpoint, not current-page counts.
- Add indexes for organizationId, stage, and lead deletion state.

Edge cases to test:

- Prospect moved to WON.
- Approved quotation for a prospect not yet won.
- Won prospect with deleted lead.
- Won prospect hard delete attempt.
- Customer stats with active and inactive linked leads.

Testing checklist:

- Verify customer list shows only organization WON prospects.
- Verify customer stats match direct database counts.
- Verify deleting converted leads/prospects is blocked after fix.
- Verify customer list pagination/search.
- Verify report and dashboard customer counts match customer module definition.

9. Reports

Severity: Medium to High

Affected functionality:

- Lead reports.
- Prospect reports.
- Quotation reports.
- Performance reports.
- CSV export.
- Filters and charts.

Bugs/issues found:

- Backend getReportsData returns summary, lead, prospect, quotation, and performance data for every report request, even when UI renders one tab.
- Report limit has no maximum. Export forces limit: 10000, so larger exports are silently truncated.
- The global Lead Source filter only affects lead reports. Prospect, quotation, performance, and summary calculations do not consistently use it.
- Performance reports compute follow-up metrics by loading follow-up activities and filtering metadata in JavaScript.
- Performance reports include only active users, so inactive users disappear from historical performance.
- activityFilters is computed but not used in the performance activity query.
- Custom date filters do not validate from <= to in report schema.

- CSV export is logged but not audited.
- Date ranges use UTC boundaries, which may not match organization-local reporting expectations.

Possible root cause:

- Unified reporting endpoint was built for simplicity.
- Filters were added generically in UI before each report type implemented them.
- Follow-up completion is stored in activity metadata, not a query-friendly column.

Best-practice solution:

- Split reports by endpoint or add a type parameter so the backend computes only the active tab.
- Add `limit.max(100)` for UI and a dedicated export job/streaming export for large data.
- Make filters tab-aware, or apply source/date/user filters consistently.
- Store follow-up completion state in structured columns or a reporting table.
- Add audit rows for exports.

Performance improvement suggestions:

- Use DB aggregation for source, stage, status, revenue, and performance metrics.
- Avoid `findMany` for large trend datasets where `groupBy` or raw SQL bucketing fits.
- Stream CSV or generate exports asynchronously for large organizations.

Edge cases to test:

- Export more than 10,000 leads.
- from date after to date.
- Source filter on prospect and quotation tabs.
- Inactive executive with historical leads and quotations.
- Reports around timezone midnight.
- Large prospect activity table.

Testing checklist:

- Verify each report count against direct DB queries.
- Verify filters apply as displayed.
- Verify CSV exports match filtered data and row count.
- Verify export creates audit row after fix.
- Verify charts render in dark and light mode.
- Verify mobile report tabs and filters.

10. Profile

Severity: High

Affected functionality:

- Admin profile update.
- Password change.
- Profile photo upload.
- Quotation PDF asset upload.

Bugs/issues found:

- Backend accepts `companyLogo`, `qrCode`, and signature files from any authenticated organization user. The UI hides PDF assets from some roles, but the API does not enforce the same role policy.
- Profile and organization asset uploads run before validation, so invalid requests can leave orphan files.
- Old profile images and old organization PDF assets are not deleted when replaced.
- Profile audit logs capture body field names but not uploaded asset field names.
- Frontend hides change-password from Manager/Executive, but backend allows any authenticated user to change own password. This may be intended, but UI and API policy differ.

Possible root cause:

- File field support was added to a general profile endpoint without a backend role gate per file type.
- Storage cleanup was not added around validation/service failures.

Best-practice solution:

- Add backend role checks for organization asset fields. If policy is Admin-only, enforce Admin-only. If Manager is allowed, explicitly allow Admin/Manager.
- Clean up uploaded files when validation or service update fails.
- Delete or archive previous asset files on successful replacement.
- Include asset field names in audit metadata.
- Align password-change UI and API policy.

Performance improvement suggestions:

- Store uploaded assets with deterministic paths or object storage keys.
- Use image optimization/resizing for profile and PDF assets.

Edge cases to test:

- Executive crafts profile request with companyLogo.
- Admin uploads invalid file type.
- Admin uploads valid file with invalid first name.
- Admin replaces logo multiple times.
- Admin changes password and old sessions are invalidated.
- Dark/light mode profile layout.

Testing checklist:

- Verify profile fields update correctly.
- Verify password change requires current password.
- Verify organization asset upload is role-gated on backend.
- Verify old files are cleaned up after replacement.
- Verify audit rows include profile image/assets after fix.
- Verify mobile profile layout.

11. Settings

Severity: Medium

Affected functionality:

- Admin settings page.
- Billing/subscription read view.
- Plan restriction visibility.

Bugs/issues found:

- Settings currently contains only the Billing tab. The page description says organization plan and preferences, but there are no actual organization preference controls.
- Tenant billing is read-only by design, which is appropriate for manual billing operations.
- No subscription is shown as an actionable state, but write gates fail open if the organization truly has no subscription row. This can conflict with Admin expectations unless backfill is guaranteed.
- Query-string tab persistence is good, but there is no actual settings persistence beyond billing read state.

Possible root cause:

- Settings page is a placeholder container around Billing.
- Billing backfill safety path intentionally fails open.

Best-practice solution:

- Either rename Settings to Billing or add real organization settings.
- Add a system invariant that active organizations must have subscription rows.

- Keep Billing readable for lapsed tenants, but make write restrictions explicit in UI banners.

Performance improvement suggestions:

- Cache subscription status briefly.
- Keep usage counts aggregated and indexed.

Edge cases to test:

- Active subscription.
- Trialing subscription.
- Lapsed subscription after grace period.
- Organization with no subscription row.
- Feature toggle off for announcements/audit/PDF.
- Admin on mobile settings page.

Testing checklist:

- Verify Admin can read billing but cannot manage plan.
- Verify usage meters match actual counts.
- Verify lapsed subscription blocks writes in tenant modules.
- Verify dashboard/reports/billing remain readable when lapsed.
- Verify Settings tab query param persists.

12. Help

Severity: Low

Affected functionality:

- Admin self-help.
- Role-specific FAQ.
- Support contact usefulness.

Bugs/issues found:

- Admin FAQ says Admin can reset a user's password, but backend allows only Super Admin password reset.
- Executive FAQ references lead statuses like Won, Lost, In Progress, and Dead, which do not match current lead statuses.
- Help search checks only FAQ questions, not answers.
- Action cards have pointer styling but no click handlers or destinations.
- Support email and emergency contact are placeholder values.
- Help content is not aware of plan restrictions or disabled features.

Possible root cause:

- Help content is static and has not been updated with the current role/permission model.

Best-practice solution:

- Update FAQs from the actual role matrix and workflow names.
- Make action cards link to docs, support email, or ticket creation.
- Search both question and answer.
- Add Admin-specific guidance for subscription limits, quotation approval, customer conversion, and PDF assets.

Performance improvement suggestions:

- Static content is fine for current scale.
- If content grows, move to structured searchable content.

Edge cases to test:

- Admin searches for "password".
- Admin searches for "quotation".
- Admin clicks User Guide, Contact Administrator, Submit Ticket.

- Help on mobile.
- Help in dark mode.

Testing checklist:

- Verify Admin FAQ contains only actions Admin can perform.
- Verify status names match enums.
- Verify support links work.
- Verify search returns answers.
- Verify empty search state.

Improvement Roadmap

Phase 0: Critical Data Integrity and Security

1. Block deletion of converted leads.
2. Remove or soft-protect prospect delete, especially for WON and LOST.
3. Validate lead productInterested item id against the Admin organization.
4. Add backend role checks for organization PDF asset uploads.
5. Fix quotation route order so /quotations/stats is declared before /:id.
6. Add rejection reason UI for quotation reject.

Phase 1: Audit and Workflow Correctness

1. Add audit events for lead assignment, item status toggle, prospect stage/follow-up/activity/delete, profile assets, and report exports.
2. Decide customer conversion policy:
 - quotation approval automatically marks prospect WON, or
 - prospect WON remains explicit and UI explains it.
3. Make dashboard KPI definitions explicit and consistent with reports/customers.
4. Align frontend and backend validation for users, prospects, and profile.
5. Add route/API tests for Admin role permissions and cross-organization attempts.

Phase 2: Data Accuracy and Scale

1. Add aggregate stats endpoints for Users, Items, and Prospects.
2. Add maximum limits to list filters across users/items/leads/prospects/reports.
3. Split Reports endpoints by active tab or type.
4. Move dashboard/report trend aggregation into database queries or summary tables.
5. Normalize follow-up date/time handling with organization timezone.

Phase 3: UX, Responsiveness, and Dark Mode

1. Fix Admin dashboard chart axis colors in dark mode.
2. Improve quotation form mobile ergonomics and searchable item/prospect selectors.
3. Add clear empty/loading/error states for partial feed loading.
4. Replace placeholder Help content and wire Help action cards.
5. Clarify Settings vs Billing naming.

Phase 4: Operational Hardening

1. Add monitoring for SUBSCRIPTION_MISSING.
2. Add cleanup for orphaned uploads and replaced assets.
3. Move large quotation attachments to object storage.
4. Add export audit and async/streamed export for large datasets.
5. Maintain a regression checklist for Admin, then repeat audit for Manager access.

Module-Wise Testing Checklist

Dashboard

- Confirm Admin dashboard is only available to Admin role.
- Compare each KPI with direct database query.
- Test empty organization.
- Test lost leads vs lost prospects.
- Test timezone-sensitive follow-ups.
- Test dark and light mode charts.
- Test large organization data.

Notifications

- Verify Admin sees only own notifications.
- Verify targeted announcement visibility by org and role.
- Verify unread count merges notifications and announcements.
- Verify mark all read clears more than 200 notifications after fix.
- Verify loading and empty states.
- Verify mobile feed rendering.

Users

- Create Manager and Executive as Admin.
- Attempt to create Admin as Admin.
- Disable, enable, and delete Manager/Executive.
- Attempt self-disable and self-delete.
- Hit seat limits on create and enable.
- Validate stats with more than 10 users.
- Verify audit rows.

Items

- Create goods and services with required HSN/SAC.
- Test duplicate item code policy.
- Toggle item status and verify audit after fix.
- Use inactive/deleted item in quotation attempt.
- Validate stats above 1000 items.
- Test mobile table cards.

Leads

- Create lead with valid organization item.
- Attempt to create lead with another organization's item id.
- Assign lead and verify audit after fix.
- Change status through every allowed value.
- Qualify and convert with prospect limit reached.
- Attempt delete of converted lead.
- Import duplicates and over-plan rows.
- Upload invalid lead photo request and verify cleanup after fix.

Prospects

- Convert qualified lead.
- Attempt conversion of non-qualified lead.
- Update stage with comment.
- Update follow-up date/time/type.
- Add call/email/meeting activity.
- Attempt delete of WON and LOST prospects.
- Verify lost stats across pages.
- Verify customer derivation from WON.

Quotations

- Verify /quotations/stats.
- Create quotation with valid active item.
- Attempt cross-org/inactive item.

- Preview PDF with logo, QR, signature.
- Reject with reason.
- Attempt reject without reason.
- Approve quotation and verify customer rule.
- Edit approved quotation.
- Test concurrent update with expectedVersion.
- Test more than 100 items/prospects in selector.

Customers

- Move prospect to WON.
- Verify customer list and stats.
- Test won prospect with deleted lead.
- Attempt destructive operations on customer source records.
- Verify dashboard/report/customer count consistency.
- Test pagination and mobile cards.

Reports

- Test each tab with same date range.
- Validate source filter behavior per tab.
- Export CSV and verify row count.
- Export more than 10,000 rows after fix.
- Test inactive users in historical performance.
- Test date range from greater than to.
- Verify export audit after fix.

Profile

- Update Admin first name, last name, and mobile.
- Change password and verify session invalidation.
- Upload profile image.
- Upload quotation PDF assets as Admin.
- Attempt PDF asset upload as Executive through API.
- Replace assets and verify old file cleanup after fix.
- Verify audit fields for asset uploads after fix.

Settings

- Read billing on active plan.
- Read billing on trialing plan.
- Read billing on lapsed plan.
- Verify writes blocked when subscription is read-only.
- Test org with no subscription row and monitor fail-open path.
- Verify feature toggles affect announcements, audit log, and PDF UI.

Help

- Search Admin FAQs by question and answer after fix.
- Verify all Admin help actions match real permissions.
- Verify action cards navigate or perform useful actions.
- Verify support contacts are real.
- Verify mobile and dark mode.